

## Chương 5 - Xác thực (Authentication)

### 5.1 Tổng quan về xác thực (Authentication)

#### A) Xác thực là gì ?

- Xác thực (authentication) là quá trình kiểm tra và
  - Các thực thể cần được xác thực gồm có:
    - User
    - Chương trình
    - Dữ liệu

#### Tiếp

- **Quá trình xác thực** có sự tham gia của hai bên
  - Bên công bố (claimant):
  - Bên kiểm tra (verifier):

## B) Phân loại xác thực

- Xác thực dữ liệu (Data Authentication): kiểm tra sự toàn vẹn và nguồn gốc của dữ liệu
- Xác thực danh tính (Identity Authentication):

## Các yếu tố sử dụng trong xác thực danh tính

- Sử dụng bằng chứng xác thực là
  - Vân tay, võng mạc, khuôn mặt, giọng nói, DNA
- Sử dụng bằng chứng là
  - Mật khẩu, mã số PIN, khóa bí mật (secret key), khóa riêng (private key)

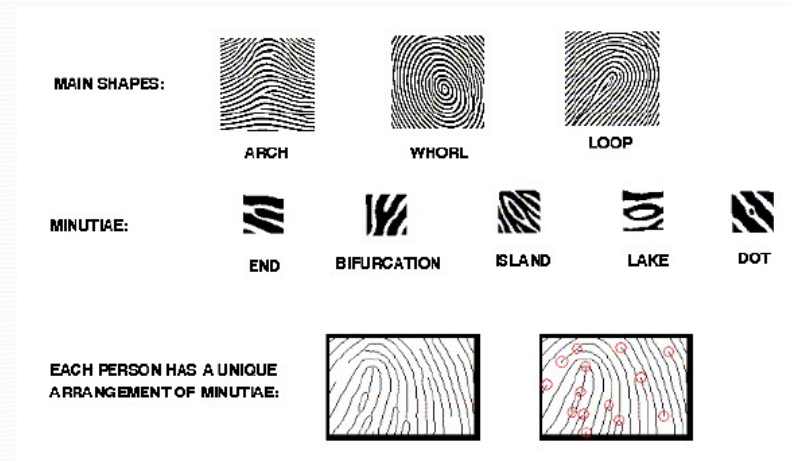
- Sử dụng
  - Căn cước điện tử có Chip bảo mật
  - Thẻ thông minh có Chip bảo mật
  - Điện thoại thông minh và SIM điện thoại
- Hiện nay hầu hết các giải pháp xác thực danh tính có

## 5.2 Xác thực danh tính bằng nhận dạng sinh trắc

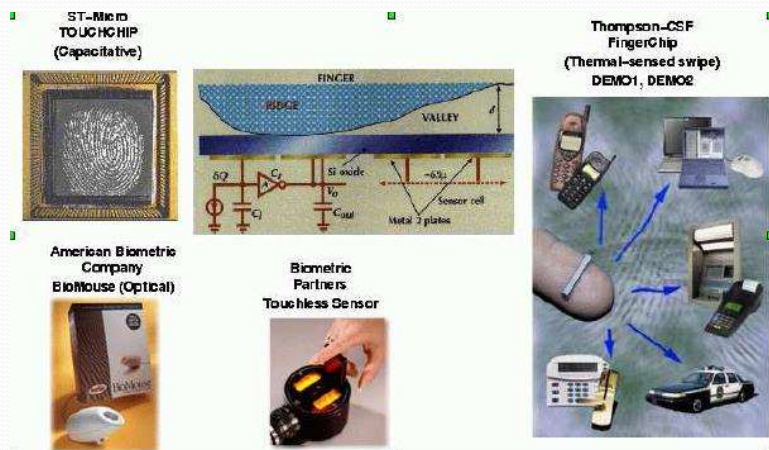
## A) Xác thực dựa trên nhận dạng vân tay (finger print)

- Các điểm đặc trưng trên vân tay được dùng làm cơ sở để xác định một mẫu vân tay
- Hình dạng và sự sắp xếp của các điểm đặc biệt này có thể coi là duy nhất với mỗi người
- Các loại thiết bị thu nhận và kiểm tra vân tay
  - Loại sensor quang: chạm đầu ngón tay lên mặt sensor
  - Sensor nhiệt hồng ngoại: quẹt đầu ngón tay qua sensor

## Một số dạng vân tay



## Chip sensor thu mẫu vân tay

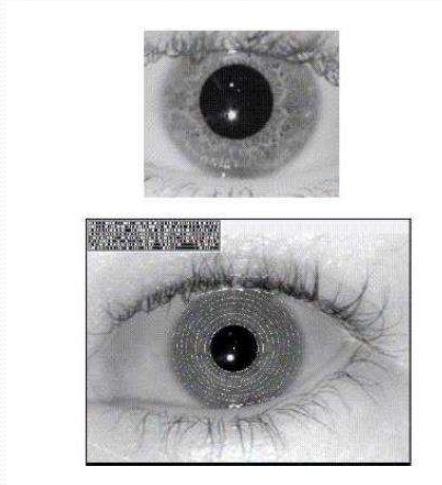


## Đặc điểm xác thực vân tay

- Tốc độ kiểm tra nhanh và dữ liệu mẫu tương đối nhỏ
- Có thể đạt độ chính xác rất cao nhưng còn phụ thuộc vào công nghệ cảm biến đọc ảnh vân tay
- Dễ triển khai và sử dụng

## B) Xác thực dựa trên võng mạc mắt (iris)

- Hình dạng, màu sắc và một số đặc điểm của võng mạc mắt cũng có tính duy nhất



## Xác thực dựa trên võng mạc (tiếp)

- Độ chính xác rất cao
- Tốc độ nhanh và dung lượng lưu trữ mẫu nhận dạng nhỏ
- Vân ảnh võng mạc rất ổn định, ít bị thay đổi theo tuổi tác
- Việc triển khai có chi phí cao do thiết bị phức tạp và chưa dễ sử dụng

## Các yếu tố sinh trắc khác

- Xác thực bằng nhận dạng khuôn mặt
- Xác thực bằng nhận dạng giọng nói.

## 5.3 Xác thực danh tính bằng mật khẩu

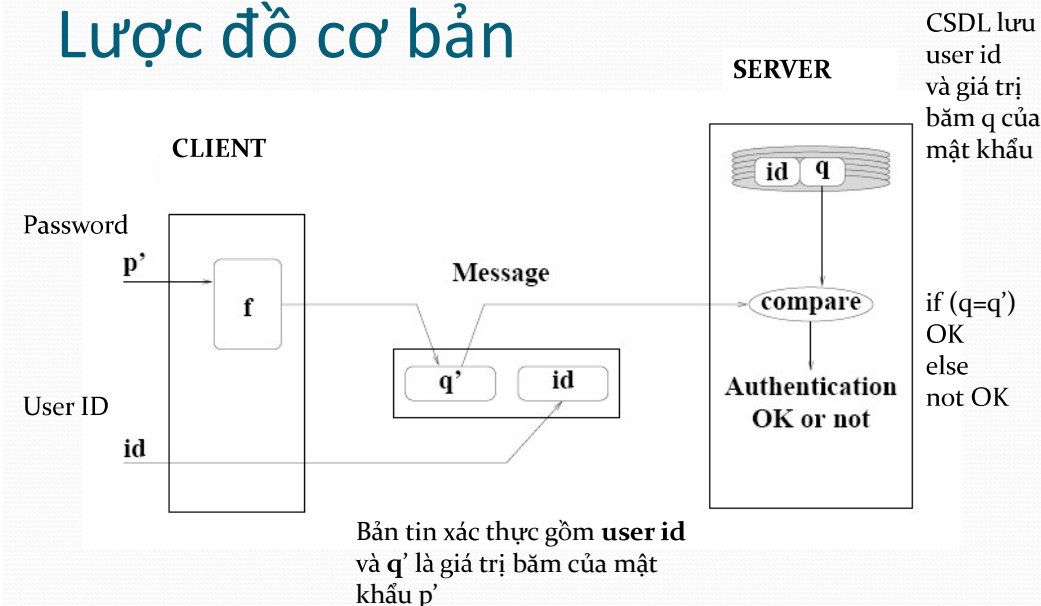
## A. Xác thực mật khẩu (Password Authentication)

- Mật khẩu (password) là
- Để bảo vệ tính bí mật, mật khẩu được mã hóa bằng một hàm băm mật mã  $f$  (có thể là MD5, SHA-1, 2, 3)
- Hàm băm có tính một chiều nên

## B. Các lược đồ xác thực bằng mật khẩu

- Sử dụng lược đồ và mã hóa mật khẩu giúp cho quá trình mật khẩu trở nên an toàn hơn trước một số các dạng tấn công ở trên
- Quá trình xác thực được mô tả bằng lược đồ hoặc giao thức xác thực giữa 2 bên Client và Server
  - Client:
  - Server:

### Lược đồ cơ bản



### Các dạng tấn công vào lược đồ xác thực đơn giản

- Tấn công phổ biến nhất là
  - Hacker lấy được một cặp  $\langle id, q' \rangle$
  - Dùng các máy tính có GPU và CPU rất mạnh để brute force) (dạng tấn công để rút ngắn thời gian tấn công)
- Tấn công phát lại (replay attack)
  - Hacker và lấy được cặp  $\langle id, q' \rangle$  trong 1 phiên khác
  - Hacker

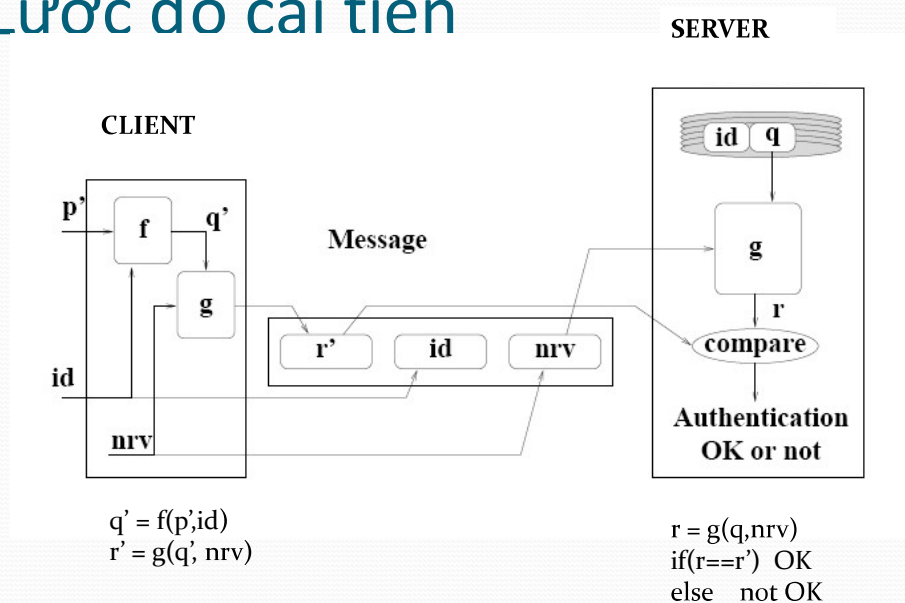
## Cách chống tấn công dò mật khẩu

- để làm cho việc truy vấn từ điển và tấn công brute force trở nên khó khăn hơn
  - Cách 1:
  - Cách 2:

## Cách phòng chống replay-attack

- Tại mỗi phiên đăng nhập, client đưa vào bản tin xác thực
- để kẻ tấn công không thể thay đổi **nrv**

## Lược đồ cải tiến



- Giá trị **nrv** được mã hóa bằng hàm **f** và **g** cùng với đầu vào là **id** và **p'**
- **Tác dụng:** khắc phục được tấn công phát lại và dò mật khẩu trên đường truyền
  - Nếu hacker phát lại thì
  - Nếu hacker thay đổi **nrv** thì

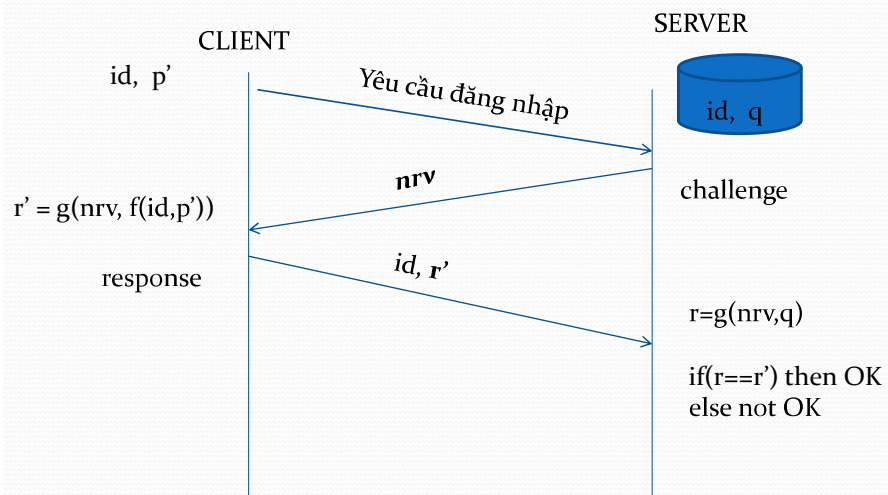
## Cơ chế thách thức – đáp ứng (challenge – response)

- Nhược điểm
  - Server phải lưu

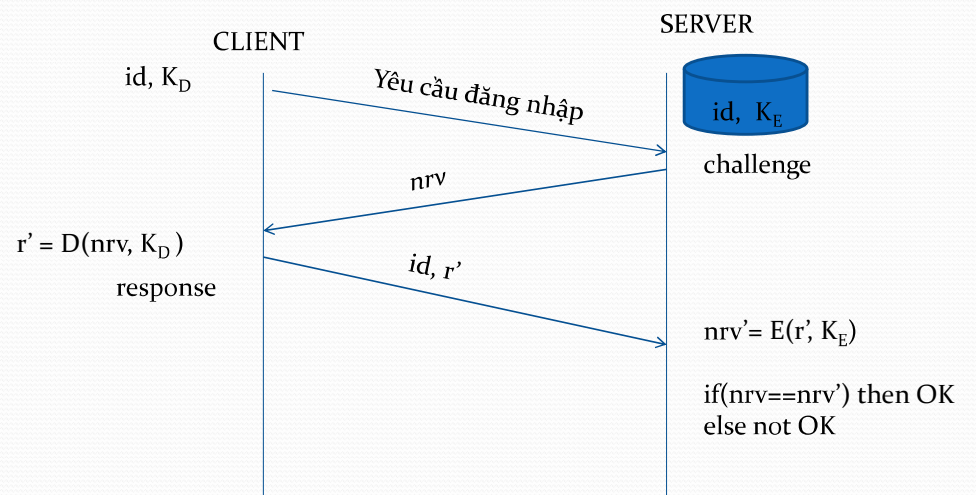
- Mỗi lần kiểm tra, server phải

- Server (challenge)
- Client gửi bản tin xác thực có chứa
- Trong cơ chế này, Server làm chủ việc tạo ra các giá trị  $nrv$  cho mỗi phiên đăng nhập

## Xác thực Challenge – Response với mật khẩu



## Xác thực Challenge – Response với khóa riêng và khóa công khai



- 
- Các giao thức xác thực mật khẩu hiện đại thường kết hợp các cơ chế sau
  - Các yếu tố bổ sung để tăng độ an toàn
    - Khóa cứng bằng USB token hoặc thẻ thông minh
    - Xác thực bằng các App Mobile của Google, Microsoft trên smartphone